

SIMATS ENGINEERING
ASSESSMENT TOOL 3 – CASE STUDY

COURSE CODE: ITA14

COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

CO4: *Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)*

Assessment Tool Weightage: 35%

Code of Conduct:

I P Reddy Swetha - 192311206 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: P Reddy Swetha

1. A mid-sized e-commerce company hosts its web application on an Apache server running on a Linux environment. Recently, customers reported unauthorized transactions and abnormal account activities. Upon investigation, the IT team discovered suspicious HTTP requests in server logs, including attempts to access hidden directories and injection of malicious scripts into input fields. Additionally, the server is running an outdated version with known vulnerabilities, and no Web Application Firewall (WAF) is implemented. As a cybersecurity analyst, you are tasked with conducting a comprehensive security assessment using Kali Linux. Analyze the possible attack vectors exploited by the attacker, including web server vulnerabilities, input validation issues, and outdated software components. Explain in detail how you would perform reconnaissance, vulnerability scanning, and exploitation using appropriate Kali Linux tools. Further, propose a layered defense strategy that includes server hardening, secure coding practices, and network-level protections to prevent such incidents in the future.
2. A financial services web application allows users to log in, view account details, and perform transactions. A recent penetration test revealed that the application is vulnerable to SQL injection and Cross-Site Scripting (XSS) attacks. Error messages expose database structure information, and user inputs are not properly sanitized. Attackers have exploited these weaknesses to extract sensitive customer data and inject malicious scripts into web pages viewed by other users. You are assigned to perform a detailed security audit of the application. Question: Examine how SQL injection and XSS vulnerabilities can be exploited in this scenario. Describe a step-by-step methodology using Kali Linux tools such as Burp Suite and SQLmap to identify and validate these vulnerabilities. Evaluate the impact of such attacks on confidentiality, integrity, and availability (CIA triad). Recommend comprehensive mitigation strategies, including input validation, output encoding, secure session handling, and implementation of security controls.
3. A corporate office provides wireless internet access to employees using WPA2-PSK authentication. Recently, several employees reported unusual login prompts and slow network performance. A security investigation revealed the presence of a rogue access point (Evil Twin) mimicking the official network SSID. Attackers used this setup to capture login credentials and perform man-in-the-middle (MITM) attacks. You are tasked with analyzing the breach and strengthening wireless security. Explain how the attacker successfully executed the Evil Twin attack and intercepted sensitive data. Describe how Kali Linux tools such as Aircrack-ng and Wireshark can be used to detect and analyze such attacks. Evaluate the weaknesses in the existing wireless security configuration. Propose robust countermeasures, including secure authentication mechanisms, network monitoring, and user awareness strategies.
4. An organization's internal network hosts a web-based employee management system accessible over Wi-Fi. The wireless network uses weak passwords, and the web application lacks proper authentication and session management. An attacker gains access to the Wi-Fi network, performs reconnaissance, and exploits vulnerabilities in the web application to escalate privileges and access confidential employee data. You are assigned to perform a full penetration testing assessment. Analyze the attack chain starting from wireless network compromise to web application exploitation. Describe each phase of the attack, including reconnaissance, scanning, exploitation, and privilege escalation. Demonstrate how Kali Linux tools can be used in each phase. Propose a comprehensive security framework that addresses both wireless and web application vulnerabilities, ensuring defense-in-depth.

5. A university campus experiences frequent Wi-Fi disruptions during peak hours. Investigation reveals repeated deauthentication attacks targeting access points, causing legitimate users to disconnect. The attacker uses automated tools to continuously send deauth packets, leading to denial of service. You are tasked with identifying the cause and implementing solutions. Explain how deauthentication attacks are carried out in wireless networks and how attackers exploit protocol weaknesses. Describe how Kali Linux tools can be used to simulate and analyze such attacks in a controlled environment. Evaluate the impact on network availability and user productivity. Recommend effective mitigation strategies, including network configuration changes, intrusion detection systems, and secure wireless protocols.

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Case	25	Thorough understanding; clearly identifies all key issues	Good understanding with most issues identified	Basic understanding; some issues missed	Poor understanding; problem not identified correctly
Application of Concepts	25	Effectively applies relevant concepts to analyze the case deeply	Applies appropriate concepts with minor gaps	Limited application of concepts	Fails to apply relevant concepts
Analysis	20	In-depth analysis with strong reasoning and insights	Good analysis with logical reasoning	Basic analysis with limited depth	Weak or no analysis; lacks reasoning
Solution Design	20	Innovative, feasible solutions with strong justification	Logical solutions with adequate justification	Basic solutions with weak justification	Incorrect or no solution provided
Clarity	10	Clear, well-structured, and easy to understand	Organized and understandable presentation	Limited clarity and structure	Poor clarity difficult to understand

① Comprehensive Security Assessment of an E-Commerce web Application.

The company is facing unauthorized transactions and abnormal account activities. The server logs also show suspicious requests, attempts to access hidden directories and malicious scripts in input fields.

Possible Attack vectors :-

The attacker may have used multiple attack vectors:
Outdated Apache server :- The old Apache version

may contain known security vulnerabilities.

XSS :- Malicious scripts may be inserted into input fields and executed in a user's browser.

SQL injection :- Poor input validation may allow attackers to manipulate database queries.

Directory Enumeration :- Hidden folders such as admin, backup or test directories may expose sensitive info.

Reconnaissance :-

The first step is to collect information about the target system.

→ Nmap can be used to identify open ports and running services : `nmap -sV <target>`

→ The -sV options help identify service versions, such as the Apache version.

→ Whatweb can be used to identify web technologies.
`Whatweb <target>`.

→ Gobuster can be used to discover hidden directories :
`gobuster dir -u <target> -w <wordlist>`

Vulnerability Scanning :-

After reconnaissance, vulnerability scanning is performed to identify weaknesses.

- Nikto can check the web server for common vulnerabilities and misconfigurations.
- Burp suite can inspect HTTP request, parameters, cookies and responses.
- SQLMap can be used to test authorized parameters for SQL injection.
- Metasploit can be used to validate known vulnerabilities in a controlled lab environment.

Controlled Exploitation :-

After identifying a vulnerabilities, I would safely verify safely verify its impact in a staging or isolated testing environment.

The analyst should determine :-

- 1) whether vulnerability is actually exploitable
- 2) What information can be accessed
- 3) Whether user accounts can be affected
- 4) whether sensitive data can be modified.

Conclusion :-

The incident is likely caused by a combination of outdated software, weak input validation, exposed directories and insufficient security controls. Kali Linux tools such as Nmap, WhatWeb, Gobuster, Nikto, Burpsuite, SQLMap, and Metasploit can help identify and validate these weaknesses.

(2)

Security Audit of SQL injection and xss

vulnerabilities:-

The financial web application stores sensitive customer and transaction information. The application is vulnerable to SQL injection and XSS because user inputs are not properly handled. These attacks can result in data theft, account compromise and unauthorized transactions.

The security audit can be performed using Kali Linux, Burp suite and SQLMap in an authorized environment.

SQL injection :- SQL injection occurs when user input

is directly included into SQL query without proper validation. An attacker can manipulate inputs and make the database perform operations.

→ Login

→ Account ID

→ Search

→ Transactions

Cross-site scripting (XSS)

XSS occurs when an application displays user input without proper output encoding. An attacker can insert malicious scripts into vulnerable fields, which may execute when another user opens page.

→ Profiles

→ Search

→ Comments

→ Feedback

Testing methodology using Kali Linux :-

→ Reconnaissance is performed to understand the applications and its services.

→ Next, Burp suite is used as a proxy between the browser and application. It allows the tester to input and modify requests, parameters, cookies.

```
sqlmap -u "https://<authorized-target>/account?  
id=1" --batch
```

→ All testing should be performed only on authorized systems and should avoid unnecessary access to real customer data.

CIA Triad Impact :-

Confidentiality :- SQL injection can expose customer and financial data, while XSS can expose information.

Integrity :- Attackers may modify account details or transaction information and perform unauthorized access.

Availability :- Malicious database requests or excessive activity may slow down or disrupt the application.

Mitigation strategies :-

- input validation : validate all user inputs on server side.
- Parameterized Queries : use prepared statements to prevent SQL injection.
- CSP : Implement Content security policy to reduce XSS risks.

Conclusion :- SQL injection and XSS are serious vulnerabilities in a financial application because they can affect confidentiality, integrity and availability. Burp suite can be used to injection.

③

Wireless Security Assessment - Evil Twin Attack:

The corporate office uses WPA 2-PSK for employee wireless access. The appearance of an Evil Twin access point indicates that attackers created a fake wi-fi network using the same SSID as the official network. Employees who connected to the fake network could have their login details and other sensitive information intercepted.

Evil Twin Attack:-

In an Evil Twin attack, the attacker creates a rogue access point with the same or similar SSID as the legitimate wi-fi network. The fake access point may provide a stronger signal so that employees connect to it.

- Capture login credentials
- Redirect users to fake login pages
- perform MITM attacks.

Detection Using Kali Linux:-

Aircrack-ng can be used by security administrators to monitor wireless networks and identify suspicious access points. It can help compare.

- | | | |
|---------|-------------------|-------------------|
| → SSID | → channel | → Encryption type |
| → BSSID | → signal strength | |

Wireshark can be used to capture and analyze network traffic. The security team can look for:

- 1) Unknown devices
- 2) Unusual authentication traffic
- 3) Unexpected DNS requests.

Weaknesses in Existing Security :-

The existing WPA2-PSK configuration has several weaknesses :

- 1) Shared password
- 2) Password reuse risk
- 3) Difficult employee identification
- 4) No individual authentication.

Countermeasures :-

Secure Authentication : The organization should preferably use WPA2-Enterprise or WPA3-Enterprise with individual employee authentication.

- Individual credentials → MFA where appropriate
- Strong authentication → Regular Credential updates
- Certificate-based authentication

Network Monitoring :-

The organization should deploy wireless intrusion Detection / Prevention systems to identify access points

- Unknown access points → MAC changes
- Duplicate SSIDs → Authentication anomalies

Conclusion :-

The Evil Twin attack was possible because the attacker created a fake access point that looked like the company's legitimate wifi network. Employees who connected to it could have their Credentials and network traffic intercepted. //

④ Full Penetration Testing Assessment of wireless and web Application Security :

The organization has two major security weaknesses a weakly protected Wi-Fi network and a web application with poor authentication and session management. An attacker can first gain access to the wireless network and then use that access to discover and attack the employee management.

Wireless Network Compromise :

The attacker first identifies nearby wireless networks and looks for weakly protected networks.
→ Tools such as Aircrack-ng can be used by an authorized penetration tester to analyze wireless network and identify security weaknesses.

Reconnaissance :-

After gaining network access, the attacker collects information about the internal systems.

→ Nmap can identify active hosts, open ports.

`nmap -sV <authorized-target>`

The tester can identify systems running :

1) HTTP/HTTPS

3) Database Services

2) SSH

4) Other network services.

This helps determine which systems require further testing.

Web Application Scanning :

The employee management system is then examined for applications vulnerability.

the tester checks :-

- Login
- sessions
- cookies

- Access controls
- user roles
- input fields

- Hidden endpoints

Web Application Exploitation :-

The lack of proper authentication and session management may allow an attacker to access functions without sufficient authorization.

- Normal users can access administrator functions.
- Session tokens remain valid for too long.
- Logout properly invalidate sessions.
- Sensitive pages can be accessed directly.

Privilege Escalation :-

After obtaining a low-privileged account, the tester checks whether privileges can be increased.

- ① Broken access control, Predictable user roles.
- ② insecure session handling.

Data Access and impact :-

If the attack succeeds, the attacker may access

- ① Employee details, salary information
- ② contact information, Attendance records
- ③ Administrative data.

Conclusion :- A defense-in-depth approach combining strong wireless authentication, network segmentation, secure web applications development, proper access control, secure sessions.

⑤

Wireless Deauthentication Attack and Mitigation :

The university is experiencing frequent wi-fi disconnections during peak hours. Investigation shows repeated deauthentication attacks, where an attacker sends fake deauthentication messages to disconnect legitimate users from the wireless network.

This attack mainly affects availability and can result in poor network performance and loss of productivity.

Deauthentication Attack :-

- Deauthentication is a normal wireless management process used to disconnect a device from an access point. In order wifi security configurations, these management frames are not always properly protected.
- Attacker → Fake Deauthentication Frames → Access Point
→ Disconnection.
- If the attacker continuously sends these packets, users may repeatedly lose their connection.

Attack simulation and Analysis :-

In an authorized laboratory environment, Kali Linux and Aircrack-ng can be used to study security.

- SSID, BSSID
- channel
- signal strength
- connected devices

Wireshark can be used to capture wireless traffic and identify repeated deauthentication frames.

Impact on Network Availability :-

A continuous deauthentication attack can have effects

- Users lose wifi connectivity
- Online classes may be interrupted
- Employees cannot access online services
- Repeated reconnection increases network load.

Mitigation Strategies :-

① Secure Wireless Protocols :- The university should use modern wireless security such as :

→ WPA3, WPA2

→ Protected Management Frames

② Network Configuration :-

- Use strong wireless authentication
- Separate users using VLANs.
- Keep access points and controllers updated.
- Use proper channel planning.
- Separate guest and internal networks.

③ Intrusion Detection :- Deploy WIDS/WIPS to

continuously monitor wireless traffic.

→ Alerts can then be generated for the security team

Conclusion :- The best defense is to use WPA3,

Protected Management Frames, WIDS/WIPS, updated access points, network segmentation and continuous monitoring. These measures can significantly improve wireless availability and reduce the impact of deauthentication attacks.